



## CIBERSEGURIDAD

# PixelMind

SGRSI · Sistema de Gestión de Recursos y Soporte de Informática  
Grupo de proyecto

| Rol             | Apellido | Nombre | Documento de identidad | Email                      |
|-----------------|----------|--------|------------------------|----------------------------|
| Coordinador     | Figueroa | Ivo    | 5.711.315-1            | ivofigueroa2169@gmail.com  |
| Sub-Coordinador | Silvera  | Bruno  | 5.736.659-4            | bsilvera2008@gmail.com     |
| Integrante 1    | Ramirez  | Ramiro | 5.791.624-0            | ramironicolas483@gmail.com |

Docente: Sindoni, Carina

## SEGUNDA ENTREGA

Fecha de entrega: 24 de agosto de 2026 — ITI · CETP

# Índice

---

- 1 · Introducción
- 2 · Mapa conceptual de amenazas en el entorno digital
- 3 · Fundamentación de la seguridad informática requerida en la empresa
  - 3.1 Activos a proteger · 3.2 Riesgos y vulnerabilidades identificados · 3.3 Justificación de la necesidad
- 4 · Objetivos de seguridad informática
- 5 · Medios para el cumplimiento de los objetivos de seguridad
- 6 · Protocolo de respuesta a incidentes
  - 6.1 Niveles de severidad · 6.2 Fases del protocolo · 6.3 Roles y responsables
- 7 · Funcionamiento de los protocolos criptográficos
  - 7.1 TLS/HTTPS · 7.2 Hashing y salting · 7.3 SSH con llaves asimétricas
- 8 · Características de los sistemas de autenticación a implementar
- Referencias** · *Anexo A: planilla de registro de incidente*

# 1 · Introducción

El presente documento corresponde a la **segunda entrega** de la unidad curricular **Ciberseguridad**, en el marco del proyecto de desarrollo del **Sistema de Gestión de Recursos y Soporte de Informática (SGRSI)**.

Esta entrega es de carácter **incremental**: incorpora la totalidad de lo presentado en la primera entrega —identificación de amenazas del entorno digital y fundamentación de la necesidad de seguridad informática— y la amplía con la definición de los objetivos de seguridad del sistema, los medios técnicos y organizativos para alcanzarlos, el protocolo de respuesta ante incidentes, el funcionamiento de los protocolos criptográficos aplicados y las características de los sistemas de autenticación a implementar.

La documentación correspondiente a la primera entrega (secciones 2 y 3) se mantiene sin modificaciones sustanciales, por no haberse recibido observaciones del cuerpo docente al respecto; los contenidos solicitados específicamente para esta instancia se desarrollan en las secciones 4 a 8.

## 2 · Mapa conceptual de amenazas en el entorno digital

El mapa siguiente integra e interpreta las principales amenazas del entorno digital, las vulnerabilidades que habilitan y los riesgos que generan sobre los sistemas informáticos y las redes de la empresa:

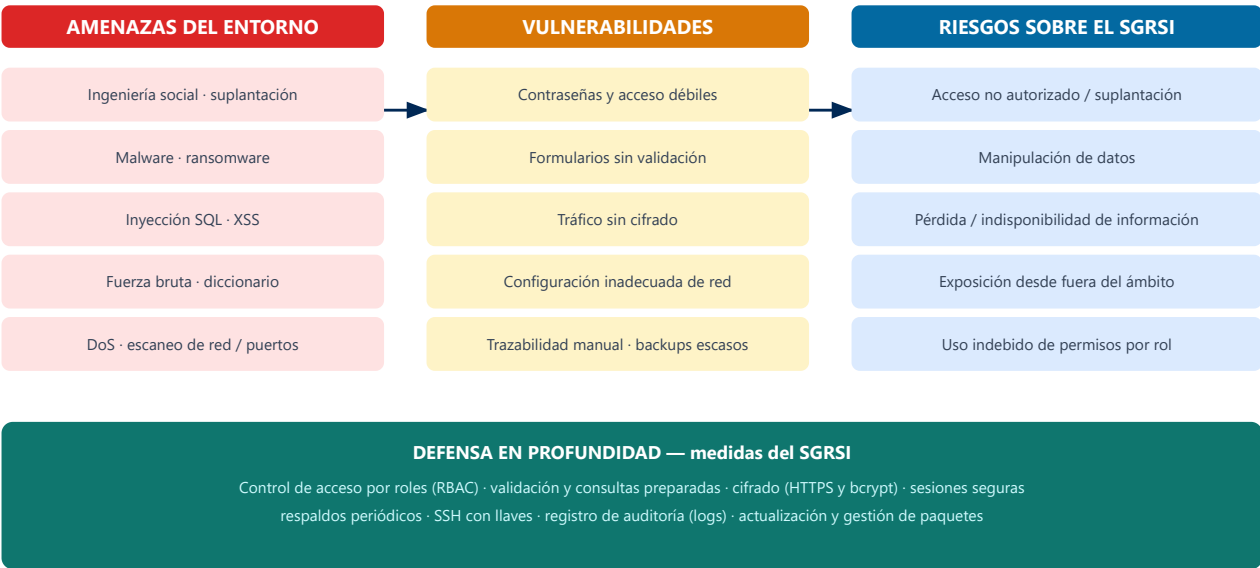


Fig. 1 · Mapa conceptual de amenazas del entorno digital para los sistemas y redes de la empresa PixelMind.

Del mapa se derivan los riesgos que se tratan en la sección 3.2 y las medidas que se definen en la sección 5.

## 3 · Fundamentación de la seguridad informática requerida en la empresa

---

El SGRSI operará como una **intranet institucional**, alojada en un servidor con sistema operativo GNU/Linux dentro de la red del instituto, y será accedida por usuarios solicitantes, técnicos y administradores desde distintos equipos conectados a dicha red. Esta arquitectura centraliza información sensible (inventario tecnológico, incidencias, credenciales de usuarios y datos personales del personal y estudiantado), por lo que la seguridad informática deja de ser un aspecto accesorio y se convierte en un **requisito estructural** del proyecto.

### 3.1 · Activos a proteger

A partir del alcance funcional definido para el SGRSI, se identifican como activos críticos:

- El **servidor** donde se alojan la aplicación y la base de datos.
- La **base de datos** en sí: inventario, tickets, solicitudes de servicio y usuarios.
- Las **credenciales de acceso** de los tres roles del sistema (solicitante, técnico/soporte y administrador/coordinador).
- La **red institucional** por la cual se transmite la información entre los equipos cliente y el servidor.

### 3.2 · Riesgos y vulnerabilidades identificados

En relación con el mapa conceptual de la sección 2, se destacan los siguientes riesgos sobre el SGRSI:

- **Acceso no autorizado y suplantación de identidad:** credenciales débiles o filtradas permitirían que un usuario no autorizado opere con permisos de técnico o administrador.
- **Inyección de código y manipulación de datos:** formularios sin validación adecuada en los módulos de inventario, tickets y solicitudes exponen al sistema a ataques sobre la base de datos.
- **Pérdida o indisponibilidad de la información:** fallas de hardware, errores humanos o ataques al servidor pueden provocar la pérdida del historial de inventario e incidencias, afectando la trazabilidad que es uno de los objetivos centrales del proyecto.
- **Errores de configuración de la red institucional:** al operar el SGRSI como intranet, una configuración inadecuada de puertos o de la red interna podría exponer el servidor a accesos no deseados desde fuera del ámbito institucional.
- **Uso indebido de permisos internos:** al existir tres roles con distintos niveles de acceso, una deficiente definición de permisos podría permitir que un usuario solicitante o técnico acceda a funciones reservadas al administrador.

### 3.3 · Justificación de la necesidad de seguridad informática

Dado que el SGRSI gestiona datos personales, credenciales de acceso e información crítica del inventario tecnológico del instituto, la incorporación de medidas de seguridad informática resulta **indispensable** para garantizar la confidencialidad, integridad y disponibilidad de la información. La aplicación de controles de acceso por rol, la protección del servidor Linux y de la red institucional, y la validación de los datos ingresados al sistema permitirán sostener la confianza de los usuarios en la herramienta y asegurar la continuidad del servicio de soporte informático que el SGRSI viene a digitalizar.

## 4 · Objetivos de seguridad informática

A partir de los activos identificados (3.1) y de los riesgos relevados (3.2), se definen y ponderan los **objetivos de seguridad** que las medidas y herramientas tecnológicas a aplicar en el SGRSI deben garantizar. La ponderación (Alta, Media o Baja) refleja el impacto que tendría el incumplimiento de cada objetivo sobre el funcionamiento del sistema y sobre la institución.

| Objetivo                   | Criticidad | Justificación                                                                                                                                                                                                              |
|----------------------------|------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Confidencialidad           | Alta       | Los datos personales del personal y estudiantado, las credenciales de acceso y el detalle del inventario tecnológico no deben quedar expuestos a usuarios sin autorización, dado su carácter sensible.                     |
| Integridad                 | Alta       | El sistema sustenta decisiones de mantenimiento, reemplazo de equipos y auditorías; un dato de inventario, ticket o historial alterado indebidamente compromete la trazabilidad, objetivo central del SGRSI.               |
| Disponibilidad             | Alta       | El SGRSI sustituye registros manuales de uso diario por la Coordinación de Informática; una caída prolongada del servidor interrumpe la gestión de préstamos, la mesa de ayuda y las solicitudes de servicio.              |
| Autenticidad               | Alta       | Debe garantizarse que cada acción registrada en el sistema (alta de un equipo, cierre de un ticket, aprobación de una solicitud) haya sido efectivamente realizada por el usuario autenticado bajo el rol correspondiente. |
| No repudio / Trazabilidad  | Media      | El historial de asignaciones e intervenciones sobre cada equipo debe poder auditarse sin que un usuario pueda negar haber realizado una acción registrada a su nombre.                                                     |
| Disponibilidad de respaldo | Media      | Ante pérdida o daño de la información original, deben existir copias recuperables que permitan restablecer el servicio en un plazo acotado.                                                                                |

Los objetivos de **Confidencialidad, Integridad y Disponibilidad** (la tríada C-I-D) constituyen el núcleo de la estrategia de seguridad del SGRSI, y sobre ellos se apoyan de forma complementaria la **autenticidad** y el **no repudio**, imprescindibles en un sistema donde múltiples roles operan sobre los mismos datos.

## 5 · Medios para el cumplimiento de los objetivos de seguridad

Para dar cumplimiento a los objetivos de la sección 4, se establecen los siguientes **medios técnicos y organizativos**, alineados con las buenas prácticas trabajadas en las restantes unidades curriculares del proyecto (Programación Full Stack y Administración de Sistemas Operativos):

- **Cifrado de contraseñas:** las credenciales se almacenan mediante funciones de hash con sal (nunca en texto plano), impidiendo que una filtración de la base de datos exponga las contraseñas reales.
- **Comunicación cifrada:** el tráfico entre los equipos cliente y el servidor se protege mediante HTTPS/TLS, evitando la interceptación de credenciales y datos sensibles en la red institucional.
- **Control de acceso por roles (RBAC):** cada funcionalidad queda habilitada únicamente para los roles que la letra define (solicitante, técnico/soporte, administrador/coordinador), verificándose siempre del lado del servidor.
- **Validación y sanitización de datos:** toda entrada de los formularios (inventario, tickets, solicitudes de servicio) se valida y sanitiza en el servidor, y las consultas a la base de datos se resuelven mediante consultas preparadas para prevenir inyecciones SQL.
- **Gestión segura de sesiones:** las sesiones se controlan del lado del servidor, con expiración por inactividad y regeneración del identificador al iniciar sesión, minimizando el riesgo de secuestro de sesión.
- **Copias de respaldo (backup):** rutinas periódicas de respaldo de la base de datos y de los archivos de configuración del servidor, almacenadas en un medio distinto al servidor de producción.
- **Segmentación y configuración de la red:** el servidor se configura con dirección estática y apertura únicamente de los puertos estrictamente necesarios, reduciendo la superficie de ataque.
- **Acceso administrativo remoto seguro:** la administración del servidor se realiza mediante SSH con autenticación por par de llaves, evitando el uso de contraseñas en las conexiones remotas.
- **Registro de auditoría (logs):** se mantiene un registro de los inicios de sesión, las acciones realizadas por cada rol y los eventos relevantes del servidor, como insumo del protocolo de respuesta a incidentes.
- **Actualización y gestión de paquetes del SO:** se mantiene actualizado el software del servidor y sus dependencias, corrigiendo vulnerabilidades conocidas de los paquetes instalados.

La correspondencia entre objetivos y medios queda trazada en la matriz de trazabilidad de la documentación de Ingeniería de Software (objetivo → control → evidencia), y cada medio tiene responsable de implementación según las rúbricas de la letra.

## 6 · Protocolo de respuesta a incidentes

Se define el protocolo que la **Coordinación de Informática** y el equipo técnico del SGRSI deberán seguir ante la detección de un incidente de seguridad, entendiendo por tal cualquier evento que comprometa la **confidencialidad, integridad o disponibilidad** de los activos identificados en la sección 3.1.

### 6.1 · Niveles de severidad

| Nivel   | Ejemplo en el SGRSI                                                                                                     | Tiempo de respuesta objetivo |
|---------|-------------------------------------------------------------------------------------------------------------------------|------------------------------|
| Crítico | Acceso no autorizado con privilegios de administrador, pérdida total de la base de datos o caída completa del servidor. | Inmediato (menor a 1 hora)   |
| Alto    | Intento de inyección SQL detectado, compromiso de credenciales de un técnico, indisponibilidad parcial del servicio.    | Menor a 4 horas              |
| Medio   | Actividad anómala en los registros de acceso, intentos reiterados de inicio de sesión fallido.                          | Menor a 24 horas             |
| Bajo    | Errores de configuración menores sin explotación confirmada, alertas preventivas de los registros del sistema.          | Menor a 72 horas             |

### 6.2 · Fases del protocolo

- **Identificación:** detección del incidente a partir de los registros de auditoría, alertas del sistema o reporte de un usuario mediante la mesa de ayuda, y clasificación según el nivel de severidad (6.1).
- **Contención:** aislamiento inmediato del alcance del incidente (revocación de la sesión o credencial comprometida, bloqueo temporal de la cuenta o del acceso a la red) para evitar que se agrave mientras se investiga.
- **Erradicación:** eliminación de la causa raíz: corrección de la vulnerabilidad explotada, actualización del paquete afectado o corrección del error de configuración identificado.
- **Recuperación:** restablecimiento del servicio a su condición normal, restauración de datos desde las copias de respaldo cuando corresponda, y verificación de que el sistema opera correctamente antes de reabrir el acceso.
- **Lecciones aprendidas:** documentación del incidente en un acta, análisis de las causas y definición de mejoras a los medios de la sección 5 para reducir la probabilidad de recurrencia.

### 6.3 · Roles y responsables

El **usuario solicitante** que detecte una anomalía debe reportarla mediante la **mesa de ayuda del propio SGRSI**, indicando la mayor cantidad de información posible. El **usuario técnico/soporte** es responsable de la identificación inicial y la contención de incidentes de severidad baja o media. Los incidentes de severidad **alta o crítica** deben ser escalados de forma inmediata al **usuario administrador/coordinador**, quien coordina la erradicación, la recuperación del servicio y la comunicación con la Dirección del instituto cuando el incidente así lo requiera.

Anexo A (al final) propone la planilla con que se registra cada incidente en las fases del protocolo, cerrando el ciclo con las lecciones aprendidas.

## 7 • Funcionamiento de los protocolos criptográficos

---

Se describe el funcionamiento de los principales protocolos y mecanismos criptográficos que se aplican en el SGRSI para sostener los objetivos de **confidencialidad, integridad y autenticidad** definidos en la sección 4.

### 7.1 • Cifrado en tránsito (TLS/HTTPS)

El protocolo HTTPS incorpora **TLS** (Transport Layer Security) sobre el protocolo HTTP utilizado por el frontend del SGRSI para comunicarse con el servidor. Al iniciarse una conexión, el cliente y el servidor realizan un intercambio (handshake) en el que el servidor presenta un **certificado digital**; a partir de dicho certificado se negocia una **clave de sesión simétrica** mediante criptografía asimétrica. Toda la comunicación posterior —incluyendo el envío de credenciales al iniciar sesión y los datos de los módulos de inventario, mesa de ayuda y solicitudes— se cifra con dicha clave de sesión, de modo que un tercero que intercepte el tráfico de la red institucional no pueda leer su contenido.

### 7.2 • Cifrado de contraseñas (hashing y salting)

A diferencia del cifrado reversible, las contraseñas se protegen mediante funciones de **hash**, que son funciones unidireccionales: transforman la contraseña en una cadena de longitud fija a partir de la cual resulta computacionalmente inviable reconstruir el valor original. Antes de aplicar la función de hash se agrega un valor aleatorio único por usuario (**sal** o salt), lo que evita que dos contraseñas iguales generen el mismo resultado almacenado y dificulta los ataques por diccionario o por tablas precalculadas (rainbow tables). Al iniciar sesión, el sistema no recupera la contraseña original: aplica la misma función de hash a la contraseña ingresada y compara el resultado con el valor almacenado.

### 7.3 • Criptografía asimétrica en el acceso remoto (SSH)

La administración remota del servidor GNU/Linux del SGRSI se realiza mediante el protocolo **SSH** (Secure Shell), configurado con autenticación basada en un **par de llaves criptográficas**: una llave privada, que permanece únicamente en el equipo del administrador, y una llave pública, distribuida y autorizada en el servidor. Dado que ambas llaves están matemáticamente relacionadas pero no es posible derivar la privada a partir de la pública, el servidor puede verificar la identidad de quien se conecta sin que la llave privada circule por la red, ofreciendo un nivel de seguridad superior al de la autenticación por contraseña.



## 8 · Características de los sistemas de autenticación a implementar

El sistema de autenticación del SGRSI debe permitir identificar de forma inequívoca a cada uno de los **tres roles** definidos por la letra (solicitante, técnico/soporte y administrador/coordinador) y sostener, a partir de dicha identificación, el control de acceso diferenciado que exige el sistema. Sus características principales son:

- **Autenticación basada en usuario y contraseña:** cada usuario se identifica mediante un nombre de usuario o correo institucional único y una contraseña, verificada en el servidor contra el valor con hash y sal almacenado en la base de datos.
- **Política de contraseñas:** se exige una longitud y complejidad mínimas al momento del registro, reduciendo la probabilidad de que una contraseña sea vulnerada por fuerza bruta.
- **Gestión de sesiones del lado del servidor:** una vez autenticado, el usuario recibe un identificador de sesión que el servidor valida en cada solicitud; la sesión expira automáticamente por inactividad y se regenera al iniciar sesión, evitando su reutilización indebida.
- **Control de acceso basado en roles (RBAC):** el rol asignado a cada usuario determina qué módulos y acciones del SGRSI puede utilizar, verificándose dicho rol en cada operación protegida del servidor.
- **Cierre de sesión explícito (logout):** el sistema permite finalizar la sesión de forma explícita, invalidando el identificador correspondiente en el servidor.
- **Bloqueo ante intentos fallidos:** se limita la cantidad de intentos de inicio de sesión fallidos consecutivos, bloqueando temporalmente la cuenta afectada y generando un registro para el protocolo de respuesta a incidentes.
- **Escalabilidad hacia un segundo factor:** el diseño del módulo de autenticación contempla incorporar en una etapa posterior un segundo factor (MFA) para el rol de administrador/coordinador, dado el nivel de acceso que posee sobre el sistema.

### 8.1 · Matriz de acceso por rol (RBAC implementado)

| Módulo del SGRSI               | Administrador / Coordinador | Técnico / Soporte     | Solicitante                |
|--------------------------------|-----------------------------|-----------------------|----------------------------|
| Usuarios                       | Gestión completa            | —                     | —                          |
| Inventario                     | Gestión                     | Gestión               | —                          |
| Préstamos                      | Gestión                     | Gestión               | —                          |
| Incidencias (mesa de ayuda)    | Seguimiento                 | Atención              | Reportar y ver las propias |
| Solicitudes de servicio        | Atención                    | Atención              | Crear y ver las propias    |
| Toma de decisiones (dashboard) | Dashboard de métricas       | Dashboard de métricas | —                          |

El acceso directo a rutas no autorizadas responde **HTTP 403**; cada operación protegida revalida el rol en el servidor, conforme al requerimiento de RBAC de la letra y de la sección 5 del presente documento.

## Referencias

- Responsable de proyecto ITI (2026). *Requerimientos de Ciberseguridad — primera y segunda entrega*. ITI · UTU CERP.
- NIST (2012). *Special Publication 800-61 Rev. 2 — Computer Security Incident Handling Guide*.
- OWASP Foundation. *OWASP Top 10 — Web Application Security Risks*.
- Stallings, W. (2017). *Cryptography and Network Security: Principles and Practice*, 7ª ed. Pearson.
- Letra del proyecto ITI 2026 — UTU CERP (entregas, roles y rúbricas).

## Anexo A · Planilla de registro de incidente

Completa el ciclo del protocolo (6.2) en su fase de *lecciones aprendidas*; se conserva junto con los logs de auditoría.

| Campo                                | Descripción                                                           |
|--------------------------------------|-----------------------------------------------------------------------|
| N.º de incidente / fecha             | Identificador correlativo y fecha/hora de detección                   |
| Detección                            | Cómo se detectó (log, alerta, reporte por mesa de ayuda)              |
| Severidad                            | Crítico / Alto / Medio / Bajo (según 6.1)                             |
| Impacto                              | Activos afectados y objetivos de seguridad comprometidos              |
| Acciones (contención → erradicación) | Resumen cronológico con responsable y hora                            |
| Recuperación                         | Restauración aplicada y verificación realizada                        |
| Lecciones aprendidas                 | Mejoras a los medios de la sección 5 y ajustes al registro de riesgos |